Splunk Cheat Sheet

Quick reference for SOC log investigation, based on TryHackMe: Splunk Basics (Did you SIEM?)

1. Basic search structure

```
index=... sourcetype=... filters | command1 | command2 | command3
```

Each | (pipe) passes the result of the previous step to the next command.

2. Filtering

Goal	Syntax
Equals	`client_ip="1.2.3.4"`
Not equal	`user_agent!=*Mozilla*`
Wildcard	`path="*backup*"`
One of several values	`path IN ("/.env", "/.git*")`
AND / OR	`(a="x" OR b="y") AND c="z"` (always use parentheses)

3. Core commands

Command	What it does	Example
`stats count by`	Counts events per value	`stats count by client_ip`
`stats sum()`	Adds up numeric values	`stats sum(bytes_transferred) by src_ip`
`sort - count`	Sort descending (highest first)	`sort - count`
`head N`	Keep the first N rows	`head 5`
`table`	Show selected columns	`table _time, path, status`
`timechart span=1d count`	Events over time	Daily event counts
`top` / `rare`	Most / least common values	`top limit=10 path`

4. Investigation templates

1) Find the abnormal day:

```
index=main sourcetype=web_traffic | timechart span=1d count | sort - count
```

2) Most active IPs:

```
index=main sourcetype=web_traffic | stats count by client_ip | sort - count | head 5
```

3) Remove normal browsers, keep tools and scripts:

```
sourcetype=web_traffic user_agent!=*Mozilla* user_agent!=*Chrome*
user_agent!=*Safari* user_agent!=*Firefox*
```

4) Trace a suspect in time order:

```
sourcetype=web_traffic client_ip="<IP>"
| table _time, path, user_agent, status | sort _time
```

5) SQL injection tools:

```
sourcetype=web_traffic client_ip="<IP>"
AND user_agent IN ("*sqlmap*", "*Havij*") | stats count by path, status
```

6) Correlate with the firewall (C2 traffic):

```
sourcetype=firewall_logs src_ip="<server>" AND dest_ip="<attacker>"
| stats count, sum(bytes_transferred) by dest_port, action, reason
```

5. Attack chain map

Stage	What to look for
Reconnaissance	`/.env`, `/.git*`, `phpinfo`
Enumeration	`..` (path traversal), `redirect`
Exploitation	`SLEEP(`, `sqlmap`, `Havij`
Exfiltration	`backup.zip`, `logs.tar.gz`
Execution / RCE	`shell.php?cmd=`, `.bin` files
Command and control	Firewall: outbound connection from the server to the attacker

6. Common mistakes

- A `200` status alone does not prove an attack succeeded. Compare response size, repetition and other log sources.
- Use parentheses with `AND` and `OR`, because `OR` is evaluated first.
- If a lab page is auto-translated, copy the English query only and type answers in English with digits 0-9.
- Date answers use the format `YYYY-MM-DD`.

7. Think instead of memorizing

- Where am I searching? (index and sourcetype)
- What do I filter on? (IP, user agent, path)
- What do I want at the end? (a count, a table, a chart)